UNIT-IV
Cybersecurity: Organizational Implications

Introduction:

In the global environment with continuous network connectivity, the possibilities for cyberattacks can emanate from sources that are local, remote, domestic or foreign. They could be launched by an individual or a group. They could be casual probes from hackers using personal computers (PCs) in their homes, hand-held devices or intense scans from criminal groups.
Most information the organization collects about an individual is likely to come under "PI" category if it can be attributed to an individual. For an example, PI is an individual's first name or first initial and last name in combination with any of the following data:

1. Social security number (SSN)/social insurance number.
2. Driver's license number or identification card number.
3. Bank account number, credit or debit card number with personal identification number such as an access code, security codes or password that would permit access to an individual's financial account.
4. Home address or E-Mail address.
5. Medical or health information.

An insider threat is defined as "the misuse or destruction of sensitive or confidential information, as well as IT equipment that houses this data by employees, contractors and other 'trusted' individuals."

Insider threats are caused by human actions such as mistakes, negligence, reckless behavior, theft, fraud and even sabotage. There are three types of "insiders" such as:

1. A malicious insider is motivated to adversely impact an organization through a range of actions that compromise information confidentiality, integrityand/or availability.
2. A careless insider can bring about a data compromise not by any bad intention but simply by being careless due to an accident, mistake or plain negligence.
3. A tricked insider is a person who is "tricked" into or led to providing sensitive or private company data by people who are not truthful about their identity or purpose via "pretexting" (known as social engineering)

Insider Attack Example 1: Heartland Payment System Fraud

- A case in point is the infamous "Heartland Payment System Fraud" that was uncovered in January 2010.
- In this case, the concerned organization suffered a serious blow through nearly 100 million credit cards compromised from at least 650 financial services companies.
- When a card is used to make a purchase, the card information is transmitted through a payment network.
- A piece of malicious software (keystroke logger) planted on the company's payment processing network; recorded payment card data as it was being sent for processing to Heartland by thousands of the company's retail clients.
- Digital information within the magnetic stripe on the back of credit/debit cards was copied by **keylogger.**
- Criminal created counterfeit credit cards.

Insider Attack Example 2: Blue Shield Blue Cross (BCBS)

- Yet another incidence is the Blue Cross Blue Shield (BCBS) Data Breach in October 2009 the theft of 57 hard drives from a BlueCross BlueShield of Tennessee training facility puts the private information of approximately 500,000 customers at risk in at least 32 states.
- The hard drives containing 1.3 million audio files and 300,000 video files related to coordination of care and eligibility telephone calls from providers and members were reportedly stolen from a leased office.
    1. Physical security is very important.
    2. Insider threats cannot be ignored.

Privacy has following four key dimensions:

1. **Informational/data privacy:** It is about data protection, and the user's rights to determine how, when and to what extent information about them is communicated to other parties.
2. **Personal privacy:** It is about content filtering and other mechanisms to ensure that the end-users are not exposed to whatever violates their moral senses.
3. **Communication privacy:** This is as in networks, where encryption of data being transmitted is important.
4. **Territorial privacy:** It is about protecting user's property.
   For example, the user devices from being invaded byundesired content such as SMS or E-Mail/Spam messages.

The keychallenges from emerging new information threats to organizations are as follows:

1. **Industrial espionage:** There are several tools available for web administrators to monitor and track the various pages and objects that are accessed on their website.
2. **IP-based blocking:** This process is often used for blocking the access of specific IP addresses and/or domain names.
3. **IP-based "cloaking":** Businesses are global in nature and economies are interconnected. There are websites that change their online content depending on a user's IP address or user's geographic location.
4. **Cyberterrorism:** "Cyberterrorism" refers to the direct intervention of a threat source toward your organization's website.
5. **Confidential information leakage:** "Insider attacks" are the worst ones. Typically, an organization is protected from external threats by your firewall and antivirus solution.

Cost of Cybercrimes and IPR Issues: Lessons for Organizations

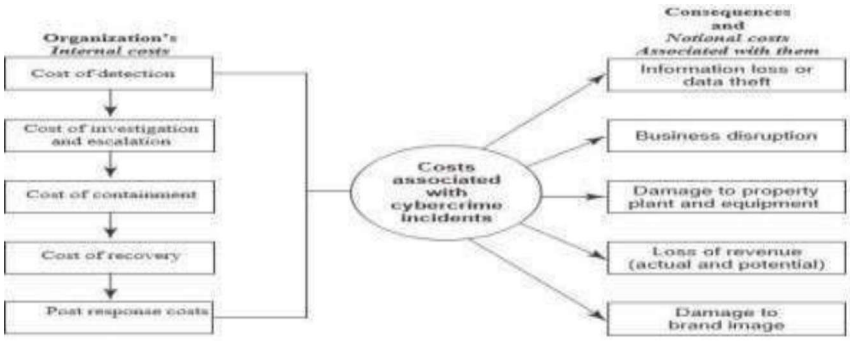


Fig: Cost of cybercrimes.

When a cybercrime incidence occurs, there are a number of internal costs associated with it for organizations and there are organizational impacts as well.

- **Organizations have Internal Costs Associated with Cyber security Incidents**
  The internal costs typically involve people costs, overhead costs and productivity losses. The internal costs, in order from largest to the lowest and that has been supported by the benchmark study mentioned:
    1. Detection costs.(25%)
    2. Recovery costs.(21%)
    3. Post response costs.(19%)
    4. Investigation costs.(14%)
    5. Costs of escalation and incident management.(12%)
    6. Cost of containment.(9%)
- The consequences of cybercrimes and their associated costs, mentioned
    1. Information loss/data theft.(42%)
    2. Business disruption.(22%)
    3. Damages to equipment, plant and property.(13%)
    4. Loss of revenue and brand tarnishing.(13%)
    5. Other costs.(10%)
- The impact on organizations by various cyber crimes
    1. Virus,worms and Trojans-100%
    2. Malwares-80%
    3. Botnets-73%
    4. Web based attacks-53%
    5. Phishing and Social engineering-47%
    6. Stolen devices-36%
    7. Malicious insiders-29%
    8. Malicious code-27%
- Average days taken to resolve cyber Attacks
    1. Attacks by Malicious insiders-42 days
    2. Malicious code-39 days
    3. Web based attacks-19 days
    4. Data lost due to stolen devices-10 days
    5. Phishing and social engineering attacks-9 days
    6. Virus,worms,and trojans-2.5 days
    7. Malware-2 days
    8. Botnets- 2 days

There are many new endpoints in today's complex networks; they include hand-held devices.

1. **Endpoint protection**: It is an often-ignored area but it is IP-based printers, although they are passive devices, are also one of the endpoints.
2. **Secure coding:** These practices are important because they are a good mitigation control to protect organizations from "Malicious Code" inside business applications.
3. **HR checks:** These are important prior to employment as well as after employment.
4. **Access controls:** These are always important, for example, shared IDs and shared laptops are dangerous. (for confidential and sensitive data).
5. **Importance of security governance:** It cannot be ignored - policies, procedures and their effective implementation cannot be over-emphasized.

Organizational Implications of Software Piracy

- Use of pirated software is a major risk area for organizations.
  From a legal standpoint, software piracy is an IPR violation crime.
- Use of pirated software increases serious threats and risks of cybercrime and computer security when it comes to legal liability.

The most often quoted reasons byemployees, for use of pirated software, are as follows:

1. Pirated software is cheaper and more readilyavailable.
2. Manyothers use pirated software anyways.
3. Latest versions are available faster when pirated software is used.

Web Threats for Organizations: The Evils and Perils

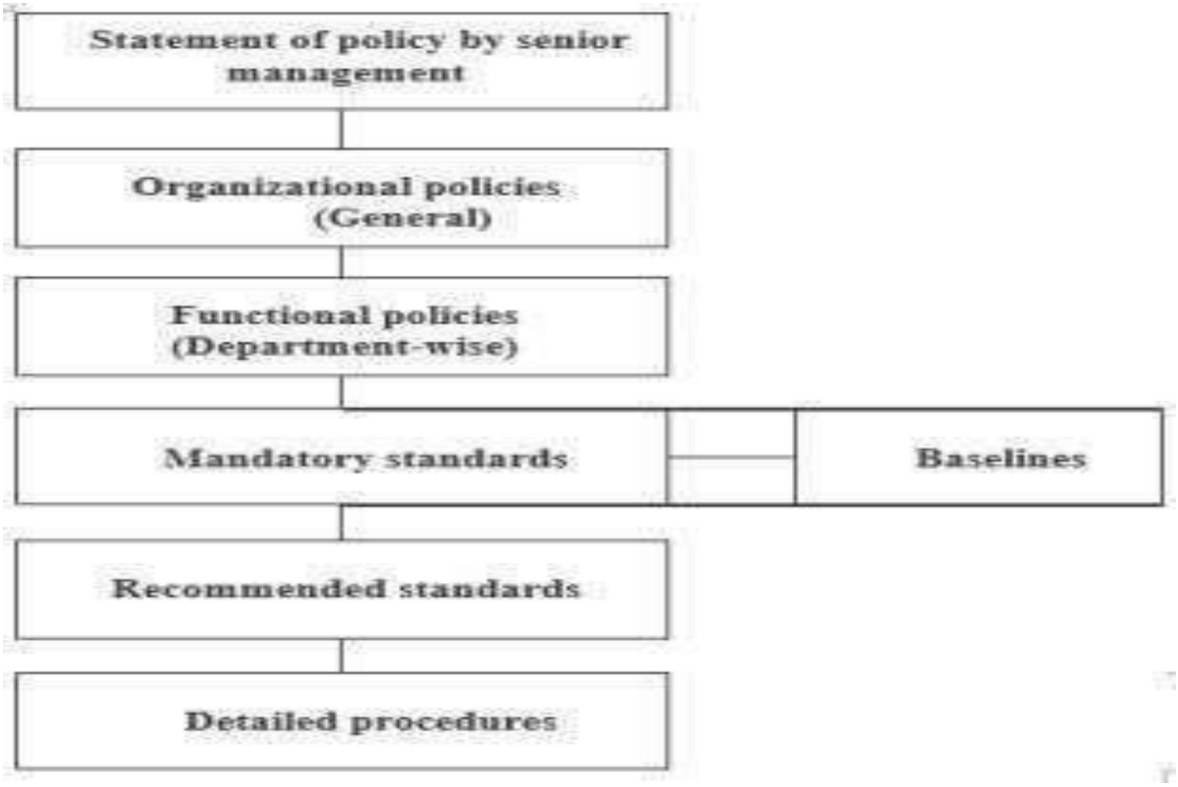
- Internet and the Web is the way of working today in the interconnected digital economy. More and more business applications are web based, especially with the growing adoption of cloud computing.
- There is inevitable dependence on the Internet. (purchase, audio, video, weather forecast, etc.,).
- Therefore, cybercriminals find it convenient to use the Internet for committing crimes.

Web threats for organizations:

1. **Overview of Web Threats to Organizations:**
   - The Internet has engulfed us! Large number of companies as well as individuals have a connection to the Internet. Employees expect to have Internet access at work just like theydo at home.
   - IT managers must also find a balance between allowing reasonable personal Internet use at work and maintaining office work productivityand work concentration in the office.

2. **Employee Time Wasted on Internet Surfing:**
   - This is a very sensitive topic indeed, especially in organizations that claim to have a "liberal culture." Some managers believe that it is crucial in today's business world to have the finger on the pulse of your employees.
   - People seem to spend approximately 45-60 minutes each working day on personal web surfing at work.
   - Organization need to discipline an employee for Internet misuse,
     1. Safe Computing Guidelines/Internet Usage Guidelines.
     2. Organization need software installed, which monitor employee's Internet activities in the background. Cookies store the surfing activities.

3. **Enforcing Policy Usage in the Organization:**
   - An organization has various types of policies. A security policy is a statement produced by the senior management of an organization, or by a selected policy board or committee to dictate what type of role securityplays within the organization.



4. **Monitoring and Controlling Employee's Internet Surfing:**
   - A powerful deterrent can be created through effective monitoring and reporting of employees' Internet surfing.
   - Even organizations with restrictive policies can justify a degree of relaxation.
   - for example, allowing employees to access personal sites only during the lunch hour or during specified hours.
   - Managers get insight into employee's web use, in close association of "cookies" with website visited during Internet Surfing.
   - HR investigations becomes possible- managers giving a broad picture of company-wide usage patterns and productivity.

5. **Keeping Security Patches and Virus Signatures Up to Date:**
   - Updating security patches and virus signatures have now become a reality of life, a necessary activity for safety in the cyberworld!
   - Keeping security systems up to date with security signatures, software patches, etc. is almost a nightmare for management.
   - Doing it properly and regularly absorbs a significant amount of time, but at same time, not doing it properly exposes IT systems to unnecessary risk.

6. **Surviving in the Era of Legal Risks:**
   - Most organizations get worried about employees visiting inappropriate or offensive websites.
   - Downloading Children Pornography, Pirated Software, inappropriate images, irresponsible comments made by employee on public Internet forum can be a breach for liability and confidentiality guidelines.
   - Serious legal liabilities arise for businesses from employee's misuse/ inappropriate use of the Internet.
   - It is quite challenging to address and reduce risks, however organizations with effective web filtering and monitoring can provide reassurance and reduce risks.

7. **Bandwidth Wastage Issues:**
    - Today's applications are bandwidth hungry; there is an increasing image content in messages and that too, involving transmission of high-resolution images.
    - There are tools to protect organization's bandwidth by stopping unwanted traffic before it even reaches your Internet connection.

8. **Mobile Workers Pose Security Challenges:**
    - Most mobile communication devices for example, the PDAs and RIM BlackBerries has raised security concerns with their use.
    - Mobile workers use those devices to connect with their company networks when they move. So the organizations cannot protect the remote user system as a result workforce remains unprotected.
    - We need tools to extend web protection and filtering to remote users, including policy enforcement.

9. **Challenges in Controlling Access to Web Applications:**
    - Today, a large number oforganizations' applications are web based.
    - There will be more in the future as the Internet offers a wide range of online applications, from webmail or through social networking to sophisticated business applications.
    - Employees often tend to use these applications to bypass corporate guidelines on security.
    - For example, to access personal E-mail or upload company data to services outside company control; sometimes, employees may use their personal mail id to send business sensitive information (BSI) for valid or other reasons. It leads to data security breach.
    - The organizations need to decide what type of access to provide to employees.

10. **The Bane of Malware:**
    - Manywebsites contain malware. Such websites are a growing securitythreat.
    - Although most organizations are doing a good job of blocking sites that declared as dangerous; cyber attackers, too, are learning.
    - Criminals change their techniques rapidlyto avoid detection.
    - The consequences of infection are severe compared with any kind of malware.

11. **The Need for Protecting Multiple Offices and Locations:**
    - Delivery from multi-locations and teams collaborating from multi-locations to deliver a single project are a common working scenario today.
    - Most large organizations have several offices at multiple locations.
    - Protecting information security and data privacy at multiple sites is indeed a major issue because protecting single site itself is a challenge.
    - In such scenario Internet-based hosted service can easilyprotect many offices.

Security and privacy implications from cloud computing

- Cloud computing is one of the top 10 Cyber Threats to organizations. There are data privacy risks through cloud computing. Organizations should think about privacy scenarios in terms of "user spheres".
- There are three kinds of spheres and their characteristics:
    1. User sphere: Here data is stored on user's desktops, PCs, laptops, mobile phones, Radio Frequency Identification (RFID) chips, etc. Organization's responsibility is to provide access to users and monitor that access to ensure misuse does not happen.
    2. Recipient sphere: Here, data lies with recipients: servers and databases of network providers, service providers or other parties with whom data recipient shares data.

Organizations responsibility is to minimize users privacy risk by ensuring unwanted exposure of personal data of users does not happen.

3. Joint sphere: Here data lies with web service provider's servers and databases. This is the in-between sphere where it is not clear to whom does the data belong. Organization responsibility is to provide users some control over access to themselves and to minimize users futures privacy risk.

Social Media Marketing: Security Risks and Perils for Organizations

- Social media marketing has become dominant in the industry. According to fall 2009 survey by marketing professionals; usage of social media sites by large business-to-business (B2B) organizations shows the following:
  - Facebook is used by 37% of the organizations.
  - LinkedIn is used by 36% of the organizations.
  - Twitter is used by 36% of the organizations.
  - YouTube is used by 22% of the organizations.
  - MySpace is used by 6% of the organizations

- Although the use of social media marketing site is rampant, there is a problem related to "social computing" or "social media marketing" – the problem of privacy threats.
- Exposures to sensitive PI and confidential business information are possible if due care is not taken by organizations while using the mode of "social media marketing."

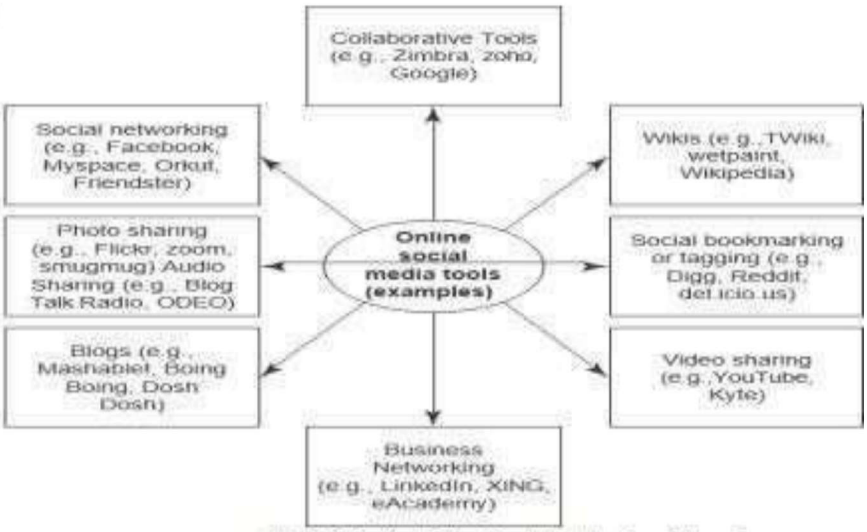


FIG: Social Media Marketing Tools

Understanding Social Media Marketing:

- Most professionals today use social technologies for business purposes.
- Most common usage include: marketing, internal collaboration and learning, customer service and support, sales, human resources, strategic planning, product development.

Following are the most typical reasons why organizations use social media marketing to promote their products and services:

1. To be able to reach to a larger target audience in a more spontaneous and instantaneous manner without paying large advertising fees.

2. To increase traffic to their website coming from other social media websites by using Blogs and social and business-networking. Companies believe that this, in turn, may increase their "page rank" resulting in increased traffic from leading search engines.
3. To reap other potential revenue benefits and to minimize advertising costs because social media complements other marketing strategies such as a paid advertising campaign.
4. To build credibility by participating in relevant product promotion forums and responding to potential customers' questions immediately.
5. To collect potential customer profiles. Social media sites have information such as user profile data, which can be used to target a specific set of users for advertising.

There are other tools too that organizations use; industrypractices indicate the following:

1. Twitter is used with higher priority to reach out to maximum marketers in the technology space and monitor the space.
2. Professional networking tool LinkedIn is used to connect with and create a community of top executives from the Fortune 500.
3. Facebook as the social group or social community tool is used to drive more traffic to Websense website and increase awareness about Websense.
4. YouTube (the video capability tool to run demonstrations of products/services, etc.) is used to increase the brand awareness and create a presence for corporate videos.
5. Wikipedia is also used for brand building and driving traffic.

- There are conflict views about social media marketing some people in IT say the expensive and careless use of it. Some illustrate the advantages of it with proper control of Securityrisk

Best Practices with Use of Social Media Marketing Tools:

1. **Establish a Social Media Policy:**
   - Use of personal blogging for work related matters should be monitored and minimized (Internet Surfing).
   - Use of policies and implementation of policy-based procedures are always essential.
   - Once the policy is created, employers should communicate it to employees and should enforce its implementation through continuous monitoring
2. **Establish Firm Processes based on the Policy:**
   - Network Security administrators need to remain up to date about the most recent risks on the Web.
   - There is a strong need to establish firm processes that are systematically linked to daily workflows.
     - For Example: Administrators should ensure that the latest security updates are downloaded and identify network attacks in time or to avoid them altogether.

3. **Establish the Need-Based Access Policy:**
   - It becomes possible to control and monitor access to critical data and to track such access at anytime.
   - This reduces the risk of information falling into wrong hands through unauthorized channels.
   - Policies should not be treated as one-time activity.
   - The policies must be kept updated and adapt them to changing circumstances.

4. **Blocking the Infected files:**
   - URL filters allow organizations to block access to known Malware and Phishing Websites.

- Access blocking can also be applied to anyother suspicious site on the Internet.
- The filter function should be kept continuously up to date by maintaining so-called black-and-White-listed Websites.

5. **Use of Firewalls:**
    - Firewalls helps organizations keep their securitytechnologyup to date.
    - Some firewalls provides a comprehensive analysis of all data traffic.
    - Deep inspection of Network traffic makes it possible to monitor the type of data traffic, the websites from which it is coming, to know the web browsing patterns and peer-to-peer applications to encrypted data traffic in SSL tunnel.
    - The firewall decrypt the SSL data stream for inspection and encrypt it again before forwarding the data to the Network.
    - This results in effective protection of Workstations and other endpoints, internal networks, hosts and servers against attacks within the SSL tunnels.

6. **Protection against vulnerability:**
    - It is possible bycarefully planning vulnerability scanning and penetration testing.
    - Vulnerabilities present a huge challenge to anycorporate network.
    - An Intrusion Prevention System (IPS) serves as a protective barrier to the corporate network.
    - An IPS automatically prevents attacks byworms, viruses and other malware.
    - Once an attack is identified, the IPS immediately stops it and prevents it from spreading in the network.

7. **Define Access to Business Application:**
    - Define "need-based" access to business applications that reside on corporate networks as well on the external sites.
    - There is a phenomenal rise in workforce mobility-this makes it even more important to assign rights for defining all network access centrally.
    - On the user level, a strong authentication via single sign-on makes the administrator's work easier.
    - As a result, a single login makes it possible for users to access only the network areas and services for which they are authorized.

8. **Securing the Intranet:**
    - The Intranets are not spared by Cyberattacks.
    - Therefore, securing the Intranets should also be included in the protection activities.
    - The Intranet of every company contains highly sensitive information pertaining to the business areas.
    - These areas need to be isolated from the rest of the internal network by using the firewalls to segment the Intranet.
    - This enables segregation of departmental Intranets.
    - For example, a company can segregate departments such as finance and accounting from the rest of the Intranet and thereby prevent infections from penetrating these critical segments of the corporate network.
    - Firewall with two demilitarized zone (DMZ) networks.

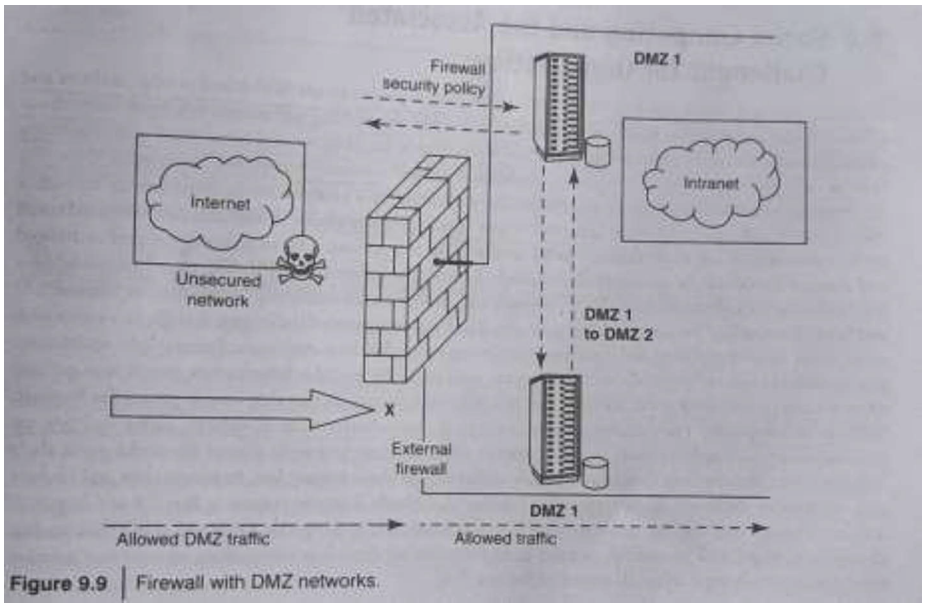


Figure 9.9 | Firewall with DMZ networks.

9. Include mobile devices in the security policy:

- It is common for users to navigate social web services with mobile devices such as laptops, PDA and Smartphones.
- The same devices are used bythe users to log into the corporate network.
- The corporate security department therefore, needs to include mobile devices in the securitypolicies.
- For example, with the assessment function by checking the login device for the required securitysettings and for the presence of securityrelevant software packages.
- Through this function, it can be checked whether the proper and latest host firewall is installed and whether both the OS and Antivirus software as well as all patches are up to date.

10. Use of centralized Management:

- Administrators can manage, monitor and configure the entire network and all devices using a single management console.
- Theycan also monitor user activities on the network by viewing reports.
- For example, System administrators will be able to know who has accessed, which data, at what time.
- This allows preventing attacks more efficiently and provide more protection for corporate applications from risk.
- The Organizational best practices are:
  - Organization-wide information systems securitypolicy;
  - Configuration/change control and management;
  - Risk assessment and management;
  - Standardized software configurations that satisfy the information systems security policy;
  - Securityawareness and training;
  - Contingency planning, continuityof operations and disaster recoveryplanning;
  - Certification and accreditation.

Social Computing and the Associated Challenges for Organizations

- Social Computing is also known as "Web 2.0".
- It empowers people to use Web-based products and services.
- It helps thousands of people across the globe to support their work, health, getting entertained and citizenship tasks in a number of innovative ways.
- In the modern era-we are "constantly Connected" to business is "24 X 7", the business where World never sleeps, people and organizations are appreciating the "Power of Social Media.
- In this process, a lot of Information gets exchanged and some of that could be confidential, Personally Identifiable Information (PII), etc.
- This would be a gold mine for the Cybercriminals.
- Getting too used to readily available information, people may get into the mode of not questioning the accuracy and reliability of information that theyreadily get from the Internet.
- Social Computing, new threats are emerging; those relate to security, safetyand privacy.
- Social Computing is related to Social Media Marketing because business leaders in product development, marketing and sales view social computing as an integral part of the evolving enterprise channel strategy.

Cybercrime and Cyber terrorism: Introduction:

Cyberattacks can come in the form of viruses, malware, email phishing, social media fraud - the spectrum of cyber threats is limitless. We are more interconnected than ever before, but for all of the advantages, that connectivity leaves us vulnerable to the risks of fraud, theft, abuse, and attack. Cybercrime can have wide-ranging impacts, at the individual, local, state, and national levels.

Organized cybercrime, state-sponsored hackers, and cyber espionage can pose national securityrisks to our countryand our critical infrastructure.

Transportation, power, and other services may be disrupted by large scale cyber incidents. The extent of the disruption is highly uncertain as it will be determined by many unknown factors such as the target and size of the incident.

Vulnerability to data breach and loss increases if an organization's network is compromised. Information about a company, its employees, and its customers can be at risk.

Individually-owned devices such as computers, tablets, mobile phones, and gaming systems that connect to the Internet are vulnerable to intrusion. Personal information may be at risk without proper security.

What is cyber crime and cyber terrorism?
cyber terrorism is defined by follow: "previously planned, politically motivated attack. against information, computer systems, computer programs and data that result with. violence against targets that are not military (civilian) by the sub - national groups or secret.

What is the impact of cyber terrorism?
An effect, most commonly violence, service disruptions, physical damages, psychosocial impacts, economic damages, or data breaches. A target, most commonly civilians, information and